



1. Información General de Servicio de TI

Nombre del servicio:	AmbarShield. Implementación de un centro de detección y respuesta ante ataques dirigidos (EDR/MDR).	Clave:	SEC – 2026 – 001
Fecha propuesta de inicio:	4 de febrero de 2026	Fecha propuesta de fin:	12 de junio de 2026
Nombre del administrador del servicio:	Huerta Vazquez Ilda Mariel		

2. Antecedentes

2.1 Evolución del Paisaje de Amenazas

Durante las últimas décadas del siglo XX y la primera del XXI, la ciberseguridad corporativa se fundamentó en el modelo de defensa perimetral y soluciones de seguridad basadas en firmas (Antivirus tradicionales). Sin embargo, a partir de la década de 2010, la sofisticación de las amenazas dio un salto cualitativo con la aparición de las Amenazas Persistentes Avanzadas (APT) y el auge del Crimen como Servicio (CaaS).

Este cambio histórico evidenció que los controles preventivos ya no eran suficientes: los atacantes modernos no solo buscan vulnerabilidades técnicas, sino que explotan el comportamiento humano y utilizan técnicas de movimiento lateral que permanecen invisibles para las herramientas convencionales durante meses.

2.2 Surgimiento de la Necesidad Operativa

La empresa nace de la identificación de una brecha crítica en el sector empresarial: la "paradoja de la visibilidad". Aunque las organizaciones han incrementado su inversión en herramientas de seguridad, la mayoría carece de la capacidad analítica para procesar el volumen masivo de alertas generado, lo que deriva en una "fatiga de alertas" y tiempos de respuesta ineficientes.

Estadísticas recientes de la industria indican que el tiempo promedio para detectar y contener una intrusión supera los 200 días. Ante esta realidad, surge nuestra consultora con la misión de democratizar el acceso a tecnologías de Detección y Respuesta en el Endpoint (EDR) y servicios gestionados (MDR), permitiendo que organizaciones de diversos sectores cierren la brecha entre la detección de un evento y su neutralización efectiva.

2.3 Misión y Diferenciación Estratégica

Nuestra propuesta no se limita a la implementación de software; responde a la necesidad de un acompañamiento especializado que combine inteligencia de amenazas (Threat Intelligence) con una capacidad de respuesta 24/7. La consultora se establece como un socio estratégico para aquellas instituciones que, debido a limitaciones de presupuesto o de talento humano especializado, requieren de un Centro de Operaciones de Seguridad (SOC) robusto, capaz de garantizar la resiliencia ante ataques de Ransomware y Phishing dirigido que hoy definen el riesgo digital.



3. Justificación técnica de servicios

La implementación de un servicio de detección y respuesta ante amenazas mediante tecnologías EDR/MDR permitirá fortalecer las capacidades de monitoreo y respuesta ante incidentes de ciberseguridad dentro de la organización. A diferencia de los antivirus tradicionales, estas soluciones utilizan análisis de comportamiento, correlación de eventos y monitoreo continuo para identificar actividades sospechosas o ataques dirigidos como ransomware o phishing. Su adopción permitirá detectar amenazas de manera más temprana, reducir los tiempos de respuesta ante incidentes y proteger la integridad, confidencialidad y disponibilidad de la información y de los activos tecnológicos críticos de la organización.

4. Alcance

El presente proyecto se centra en el diseño, despliegue y configuración de un marco operativo de ciberseguridad basado en capacidades de Detección y Respuesta (EDR/MDR). El alcance se desglosa en los siguientes niveles:

4.1 Alcance Tecnológico y Operativo

- **Implementación de Agentes (EDR):** Instalación y despliegue de agentes de monitoreo en una infraestructura crítica compuesta por [X número o tipo, ej: servidores centrales y estaciones de trabajo de alta dirección].
- **Configuración de Políticas:** Definición de reglas de detección basadas en comportamiento (heurística) y firmas para la identificación de Ransomware, Malware polimórfico y ataques de día cero.
- **Integración de Telemetría:** Centralización de eventos en una consola de gestión que permita la correlación de datos en tiempo real y el análisis forense básico.
- **Gestión de Incidentes (MDR):** Establecimiento de un flujo de trabajo para el triaje de alertas, priorización de amenazas y mitigación de falsos positivos.

4.2 Entregables del Proyecto

Como resultado de la consultoría, se entregarán los siguientes productos:

- **Matriz de Riesgos y Activos:** Identificación de los puntos críticos donde se priorizará la detección.
- **Manual de Configuración EDR:** Documentación técnica de los parámetros y umbrales establecidos en la herramienta.
- **Playbooks de Respuesta Inicial:** Guías de acción estandarizadas para la contención de incidentes (ej: aislamiento de red de un host comprometido).
- **Tablero de Control (Dashboard):** Visualización de KPIs como el tiempo medio de detección (MTTD) y volumen de alertas procesadas.

4.3 Exclusiones y Límites (Fuera de Alcance)

Para delimitar la responsabilidad de la consultora en este marco de trabajo, se establece que:

- **Hardware:** No incluye la adquisición, reparación o mantenimiento de equipos físicos (servidores, laptops, routers).
- **Seguridad Física:** Queda fuera la protección de accesos a las instalaciones u oficinas.
- **Remediación Total:** El servicio se limita a la detección y respuesta lógica (aislamiento y bloqueo); no incluye la recuperación de datos desde copias de seguridad (Backups) ni el cumplimiento legal ante autoridades.
- **Auditoría de Código:** No se realizará análisis de vulnerabilidades en el código fuente de las aplicaciones internas de la organización.



5. Objetivo

Diseñar e implementar un marco de trabajo de ciberseguridad centrado en un servicio de Detección y Respuesta (EDR/MDR), mediante el despliegue de capacidades de monitoreo continuo, análisis de comportamiento y correlación de eventos, con el fin de fortalecer la protección de los activos tecnológicos críticos y garantizar la resiliencia operativa de la organización ante amenazas persistentes avanzadas.

5.1 Objetivos Específicos

- Diagnosticar el estado actual de la infraestructura tecnológica y los vectores de ataque críticos para identificar brechas de visibilidad.
- Configurar la arquitectura del sistema EDR (Endpoint Detection and Response) para el monitoreo continuo y la recolección de telemetría en los nodos de la red.
- Establecer protocolos de respuesta ante incidentes (Playbooks) que automaticen la contención de amenazas detectadas por el servicio MDR.
- Definir métricas e indicadores clave de desempeño (KPIs) para evaluar la eficacia de la detección y la reducción de los tiempos de respuesta.
- Validar la operatividad del marco de trabajo mediante simulaciones de ataques controlados (Red Teaming) para asegurar la integridad de la respuesta.

6. Riesgos clave

La siguiente tabla describe los riesgos críticos identificados para la implementación del marco de trabajo EDR/MDR, categorizados para permitir una gestión focalizada durante las etapas de despliegue y operación.

Categoría	Riesgo	Descripción	Impacto	Probabilidad
Técnico	Configuración inicial inadecuada	Generación de una cobertura parcial de <i>endpoints</i> o eventos críticos no monitoreados.	Pérdida de visibilidad en activos clave, permitiendo que amenazas reales evadan la detección.	Media
Operativo	Saturación por Falsos Positivos	Alta generación de alertas erróneas que sobrepasan la capacidad del equipo de monitoreo.	Disminución de la eficiencia, retraso en la atención de incidentes reales y posible omisión de alertas críticas.	Alta
Humano	Resistencia al Cambio	Oposición del personal técnico o usuarios finales ante la instalación de agentes y nuevas políticas operativas.	Retrasos en el cronograma de despliegue y áreas de la organización que permanecen sin protección.	Media
Estratégico	Dependencia del Proveedor	Supeditación excesiva al SOC externo para la operación y escalamiento de incidentes.	Una respuesta tardía del tercero afecta directamente la contención de ataques y la continuidad del negocio.	Media
Integración	Incompatibilidad Tecnológica	Integración deficiente con herramientas existentes (SIEM, AD, Firewall o gestión de tickets).	Limitación en la correlación de eventos y reducción de la capacidad de respuesta coordinada ante incidentes.	Media

Tabla 1. Descripción de riesgos.



7. Beneficios esperados

La implementación del servicio EDR/MDR trasciende la simple instalación de software; representa una evolución en la postura de defensa de la organización. Los beneficios se categorizan en impactos medibles (tangibles) y mejoras estratégicas de percepción y cultura (intangibles).

7.1 Beneficios Tangibles (Métricas de Desempeño)

- **Optimización del Ciclo de Vida del Incidente (MTTD y MTTR):**
El beneficio más crítico es la reducción del "Dwell Time" (tiempo de permanencia del atacante). Al implementar monitoreo proactivo, buscamos reducir el MTTD (Mean Time to Detect) de meses a minutos. Esto impacta directamente en el MTTR (Mean Time to Respond), permitiendo la ejecución de acciones automáticas (como el aislamiento del host) antes de que el atacante logre el movimiento lateral o la exfiltración de datos.
- **Reducción de la Superficie de Ataque y Visibilidad 360°:**
Se logra un control total sobre el parque informático, permitiendo identificar Shadow IT (dispositivos no autorizados) y vulnerabilidades en tiempo real. La telemetría avanzada elimina los puntos ciegos en la red, asegurando que cada evento en los endpoints sea registrado y analizable.
- **Eficiencia Operativa y Mitigación de "Fatiga de Alertas":**
Mediante la correlación inteligente de eventos y el filtrado del servicio MDR, se espera reducir en más de un 80% el volumen de alertas irrelevantes (falsos positivos) que llegan al equipo de TI. Esto permite que el personal se concentre únicamente en incidentes de alta criticidad.

7.2 Beneficios Intangibles (Valor Estratégico)

- **Resiliencia y Continuidad del Negocio:**
Más allá de evitar un ataque, el beneficio es la garantía de que la organización puede resistir un intento de intrusión sin detener sus operaciones. Esto protege la cadena de suministro y asegura que los servicios críticos para el cliente final no sufran interrupciones, mitigando pérdidas financieras catastróficas.
- **Fortalecimiento del Valor de Marca y Confianza:**
En un mercado digitalizado, la ciberseguridad es un diferenciador competitivo. Contar con un marco de trabajo de detección avanzada proyecta una imagen de madurez y profesionalismo, aumentando la confianza de los socios comerciales, inversionistas y clientes finales al saber que su información está protegida bajo estándares de élite.
- **Cumplimiento Normativo y Seguridad Jurídica:**
El proyecto facilita el cumplimiento de marcos legales y estándares internacionales (como el NIST Cybersecurity Framework o la ISO/IEC 27001). Esto reduce la exposición a multas por brechas de datos y proporciona evidencia forense sólida en caso de requerimientos legales o auditorías externas.
- **Transformación de la Cultura de TI:**
Al delegar las tareas operativas de monitoreo al servicio MDR, el departamento de TI evoluciona de un rol reactivo ("apagar fuegos") a un rol estratégico. El talento humano puede dedicarse a la innovación, mejora de procesos y transformación digital, elevando la moral del equipo al reducir el estrés por incidentes no controlados.



8. Planeación Alto Nivel

8.1 Cronograma de alto nivel

La ejecución exitosa de un marco de trabajo de ciberseguridad requiere una orquestación precisa de recursos humanos, tecnológicos y temporales. Esta sección presenta la hoja de ruta estratégica para la implementación del servicio EDR/MDR, abarcando desde el diagnóstico inicial el 4 de febrero hasta el cierre operativo el 12 de junio. La planificación se ha estructurado en cinco fases lógicas bajo una metodología de ruta crítica, asegurando que el equipo de tres consultores asigne sus esfuerzos de manera eficiente para garantizar la visibilidad total y la resiliencia de los activos críticos de la organización.

Fase	Semanas	Rango de Fechas	Actividad Principal	Entregable	Responsable (Rol/Recurso)
1. Relevamiento y diseño	1 - 4	04 feb - 27 feb	Auditoría de inventario de activos críticos y diseño de la arquitectura de red para el EDR.	Documento de Arquitectura y Matriz de Activos.	Cibersecurity Architect
2. Configuración Base	5 - 8	02 mar - 27 mar	Instalación de la consola de gestión (Cloud) y creación de políticas de seguridad iniciales.	Consola Operativa y Manual de Políticas.	MDR Operations Engineer
3. Despliegue progresivo	9 - 13	30 mar - 01 may	Instalación de agentes en servidores (Semanas 9-10) y estaciones de trabajo (Semanas 11-13).	Reporte de Cobertura de Agentes.	MDR Operations Engineer
4. Optimización y Pruebas	14 - 17	04 may - 29 may	Ajuste de falsos positivos, creación de Playbooks y simulacros de ataque controlado (Red Teaming).	Playbooks de Respuesta e Informe de Simulación.	Cibersecurity Architect
5. Cierre y Capacitación	18 - 19	01 jun - 12 jun	Transferencia de conocimiento al equipo técnico y entrega de tableros de control finales.	Acta de Aceptación y Dashboards de KPIs.	Project Manager



8.2 Personal involucrado

Perfil	Iniciales	Número	Responsabilidades Clave	Tipo de Contratación	Grupo
Project Manager & Compliance	PM	1	Gestión de cronograma, contacto con el cliente y validación de normas (NIST/ISO).	Interno (Socio)	Alta dirección
Cibersecurity Architect	CA	1	Diseño lógico, configuración de consola EDR y definición de reglas técnicas.	Interno (Socio)	Ingeniería
MDR Operations Engineer	OE	1	Despliegue de agentes, respuesta inicial a incidentes y monitoreo de alertas.	Interno (Socio)	Operaciones



9. Justificación económica de proyecto de TI

El mercado actual de ciberseguridad ha migrado de soluciones estáticas a modelos de suscripción de Seguridad Gestionada (MDR). Según informes de Gartner y Forrester, las empresas que no cuentan con visibilidad de endpoints (EDR) enfrentan costos de recuperación posincidente hasta 3 veces más altos que las que cuentan con detección proactiva. Nuestra solución compite con proveedores globales como CrowdStrike o SentinelOne, pero adaptada a la escala y presupuesto de la organización mediante un esquema de gestión híbrida.

9.1 Estudio de mercado

El mercado actual de ciberseguridad ha migrado de soluciones estáticas a modelos de suscripción de Seguridad Gestionada (MDR). Según informes de Gartner y Forrester [1], las empresas que no cuentan con visibilidad de endpoints (EDR) enfrentan costos de recuperación posincidente hasta 3 veces más altos que las que cuentan con detección proactiva. Nuestra solución compite con proveedores globales como CrowdStrike o SentinelOne, pero adaptada a la escala y presupuesto de la organización mediante un esquema de gestión híbrida

9.2 Costos de mantenimiento

Suscripción Anual de Licencias por Nodo (Licenciamiento EDR): Se refiere al pago recurrente por el derecho de uso de la tecnología de detección en cada punto final (endpoint). Este costo garantiza el acceso a la consola de administración, el soporte técnico directo del fabricante y las actualizaciones constantes del motor de análisis local para enfrentar nuevas variantes de malware.

Actualización de Base de Datos de Inteligencia (Threat Intelligence Feeds): Es el costo por la suscripción a fuentes de datos globales que alimentan al sistema con indicadores de compromiso (IoC) actualizados en tiempo real. Esto permite que la herramienta reconozca tácticas, técnicas y procedimientos (TTPs) utilizados por grupos de atacantes activos a nivel mundial.

9.3 Costos de producción

Pago Mensual por Monitoreo 24/7 (Fee del Servicio MDR): Representa la inversión en capital humano especializado. Este pago cubre la disponibilidad de analistas de seguridad en un Centro de Operaciones de Seguridad (SOC) externo, quienes realizan el triaje de alertas, investigación de incidentes y respuesta inmediata ante amenazas, eliminando la necesidad de que la empresa contrate personal propio en tres turnos.

Consumo de Ancho de Banda y Almacenamiento de Telemetría: Se refiere a los costos operativos de infraestructura de red. Los agentes instalados envían metadatos y registros de comportamiento (telemetría) de forma constante hacia la nube para su correlación. Este rubro cubre el flujo de datos y el espacio de almacenamiento necesario para conservar la evidencia forense de los eventos detectados.

9.4 Inversión Inicial de Proyecto (CapEx)

Esta tabla detalla los costos de salida de la consultoría, correspondientes a las fases de diagnóstico y despliegue técnico que realizará el equipo de tres integrantes.



Categoría	Concepto	Cantidad	Costo Unitario	Total Inicial
CapEx	Consultoría, Diagnóstico y Diseño de Arquitectura	1	\$45,000	\$45,000
CapEx	Implementación, Configuración y Despliegue (100 nodos)	1	\$55,000	\$55,000
CapEx	Capacitación y Transferencia de Conocimiento	1	\$15,000	\$15,000
TOTAL	Inversión Inicial de Capital (Sin IVA)	\$11,5000		

9.5 Presupuesto General de Operación Anual (OpEx)

Esta tabla proyecta los gastos recurrentes necesarios para mantener la protección activa durante el primer año de servicio.

Categoría	Concepto	Frecuencia	Cantidad	Monto Estimado (MXN)
OpEX	Licenciamiento EDR (Suscripción por 100 nodos)	Anual	1	\$95,000
OpEX	Fee de Servicio MDR (Monitoreo 24/7 y SOC)	Mensual	12	\$260,000
OpEX	Almacenamiento de Telemetría e Inteligencia Cloud	Mensual	12	\$65,000
TOTAL	Gasto Operativo Anual Proyectado	\$420,000		

10. Conclusión General del Proyecto

La implementación de este marco de trabajo no debe visualizarse como un gasto tecnológico, sino como una estrategia de resiliencia financiera. A través del despliegue de 19 semanas, el equipo consultor garantiza la transición de una defensa pasiva a una capacidad de respuesta proactiva. Considerando que el costo de recuperación tras un incidente de Ransomware en el sector empresarial puede superar los \$1,000,000 MXN (entre rescate, multas y pérdida de productividad), el proyecto se justifica mediante la fórmula de gestión de riesgos: $ALE = SLE \times ARO$

Al reducir el impacto (SLE) mediante la detección inmediata, la inversión anual de \$535,000 MXN (CapEx + OpEx año 1) ofrece un retorno de inversión positivo al prevenir el primer evento crítico. En última instancia, este proyecto asegura la continuidad del negocio y protege el activo más valioso de la organización: su información.



11. Glosario de términos

- **Aislamiento de Host:**
Acción de desconectar virtualmente una computadora de la red de la empresa para que un virus no se propague, pero manteniendo la conexión con el SOC para que los expertos puedan limpiarla remotamente.
- **Análisis de Comportamiento:**
A diferencia de un antivirus que busca "virus conocidos", esta tecnología observa qué está haciendo el equipo. Si una computadora empieza a cifrar archivos masivamente o a enviar datos a un país extraño, el sistema la bloquea automáticamente por actuar de forma sospechosa.
- **Ataque de Día Cero (Zero-day):**
Una amenaza que explota una vulnerabilidad en el software que aún no es conocida por el fabricante. Como no hay "vacuna" previa, solo herramientas inteligentes como el EDR pueden detectarlos por su comportamiento sospechoso.
- **Caza de Amenazas (Threat Hunting):**
Proceso proactivo donde los especialistas del SOC buscan huellas de atacantes que podrían estar ocultos en la red sin haber activado ninguna alarma todavía. Es como tener un guardia que patrulla en lugar de uno que solo espera a que suene la sirena.
- **Cobertura de endpoints:**
Alcance real de protección y monitoreo que tiene la solución sobre los dispositivos definidos dentro del entorno tecnológico.
- **EDR (Endpoint Detection and Response):**
Solución de ciberseguridad enfocada en detectar, investigar y responder a amenazas en equipos finales como computadoras, laptops y servidores.
- **Endpoint:**
Dispositivo final conectado a la red que puede ser monitoreado y protegido, como una PC, laptop, servidor o dispositivo móvil.
- **Falso positivo:**
Alerta generada por una herramienta de seguridad que parece indicar una amenaza, pero que después de revisarse no corresponde a un incidente real.
- **MDR (Managed Detection and Response):**
Servicio administrado de monitoreo, detección y respuesta ante amenazas, operado por especialistas externos o por un proveedor de seguridad.
- **Movimiento Lateral:**
Técnica que usa un atacante tras entrar a una computadora para saltar a otros servidores o equipos de la empresa buscando información más valiosa.
- **Phishing:**
Correos electrónicos o mensajes engañosos que fingen ser de fuentes legítimas (bancos, proveedores, directivos) para robar contraseñas o instalar virus en la red.
- **Playbook:**
Un manual de procedimientos estandarizados que indica paso a paso qué deben hacer los técnicos ante un ataque específico (ej. "Si detectamos Ransomware, aislar el servidor X y notificar al Gerente Y").
- **Ransomware:**
Un tipo de software malicioso que "secuestra" la información de la empresa cifrándola (poniéndole un candado digital) y exige un pago para liberarla. Es la mayor amenaza para la continuidad operativa hoy en día.
- **Resiliencia Operativa:**
La capacidad de la empresa para resistir un ataque y volver a la normalidad lo más rápido posible, minimizando las pérdidas económicas o de reputación.
- **SIEM (Security Information and Event Management):**



Plataforma que centraliza, correlaciona y analiza eventos de seguridad provenientes de distintas fuentes tecnológicas.

- **SOC (Security Operations Center):**

Centro de operaciones de seguridad encargado de monitorear eventos, analizar alertas y coordinar la respuesta ante incidentes.

- **Telemetría:**

La recopilación de datos detallados sobre lo que sucede en cada computadora (clics, archivos abiertos, conexiones a internet). Es la "caja negra" que nos permite entender qué pasó después de un incidente.